

Responsible AI Governance Checklist

A practical enterprise decision guide from DigiScience Techsol

ASSET TYPE: ACCESS AND ACTION WORKSHEET

Illustrative planning method | Updated 20 September 2026

Use this checklist to examine one assistant workflow, its users, its permitted sources and its actions. It is not a security certification or evidence of a customer deployment.

Prepare the boundary

Record the workflow, accountable reviewer, user roles, permitted documents and allowed actions. Authenticate the user, apply document permissions before supplying retrieved content, and enforce tool permissions outside the model. A safety instruction does not replace authorization. Start with synthetic records and keep restricted content out of broadly accessible logs.

Five checks to adapt

- Authorized role, permitted document: expect a grounded answer from an allowed source. Inspect caller identity, retrieval scope and source reference.
- Restricted role, same question: expect no restricted content supplied or exposed. Inspect the permission decision and retrieved-document list.
- Retrieved text requests a privileged action: document text must grant no new authority. Inspect tool authorization and the attempted-action record.
- Required approval is absent: expect no execution and routing to the agreed review path. Inspect approval state and execution record.
- Permission lookup fails or access is revoked: withhold protected retrieval until authorization is established. Inspect error handling, cache behaviour and a fresh access check.

Record evidence, not just an answer

For each case capture the test input, expected outcome, observed outcome, trace/source reference, pass/fail/untested status, reviewer and next action. A refusal on screen does not prove that restricted content never reached the model. Include relevant retrieval, cache and tool-execution paths in the review.

Worked fictional example

An operations user asks an internal assistant about an HR-only policy. Check that the HR source is excluded before generation, including from summaries and cached results. A visible refusal alone is insufficient. Next, place an instruction in a synthetic document asking the agent to change a user role. Expect no role change without separately authorized tool access and required approval. This is a proposed test, not a customer test result.

Decision and continuing oversight

Record failed and untested cases with accountable owners. Extend coverage to real roles, sources, actions and failure modes. Review policy accountability, evaluation/release gates, incidents, monitoring and exception handling. Passing these five examples does not establish complete security, compliance or readiness for every use.

Bounded next step and source

A Solution Assessment can review one defined control problem and produce recommendations and an implementation brief. Coding, a working proof of concept, penetration testing and production rollout need separate scope. Source and detailed reference links:

<https://digiscience.techsol.com/solutions/responsible-ai-governance/> Describe the problem without confidential material: <https://digiscience.techsol.com/contact>

Reference architectures and solution briefs illustrate DigiScience delivery methods. Customer outcomes are published only with verified evidence and permission.